〔NEXUS WORK 조 회의록 및 활동일지〕 2026.10.19(월)

■ 활동 날짜 및 참여 조원

- 날짜: 2026-10-19(월), 오전 디스코드 텍스트 회의 + 개별 작업
- 참여: 진혜정(조장), 김태빈, 이시헌, 홍주형

■ 당일 회의 주제 및 활동 목표

- 주제: 프로젝트 기획서와 팀원별 작업 계획서 검토
- 목표: 제출 전에 기획서 내용에 문제가 없는지 확인하고, 10/23까지 구축을 끝내는 일정에 팀이 동의하는지 확인

■ 조원별 활동 내역

- 진혜정: 기획서와 팀원별 작업 계획서를 PDF로 만들어 공유하고 검토를 진행. 팀원 질문에 답하고 일정(10/23 구축 완료)을 설명. 오늘 기한 작업인 n8n 구동(Docker)과 Graylog Webhook 수신 설정을 완료. 규칙별 시험 알림 수신, 출발지 IP별 티켓 기록(같은 IP는 갱신·승격), 웹훅 토큰 검증(틀리면 401), Discord 알림 연결, 정상 IP 제외(화이트리스트), 티켓 조회·종료·오탐 처리와 상황판 화면까지 구현. 김태빈 님의 보안 로그 명세에 맞춰 n8n이 R1~R12 표준 형식을 받도록 확장하고 같은 알림의 중복 처리를 막았으며, 명세의 시험용 입력 13건으로 수신·분기를 시험
- 김태빈: 기획서를 검토하고 직접/간접 프롬프트 인젝션의 구분 방식에 의견을 제시. 오늘 기한 작업(Wazuh manager·포털 agent 연결, 문서함·업로드 폴더 FIM)을 수행. 보안 로그 명세 초안(v1.1)을 작성해 팀에 공유: ① 앱·AI Gateway·Wazuh 이벤트의 로그 공통 필드 정의(원문·비밀값은 기록하지 않는 정책 포함) ② Graylog 탐지 규칙 R1~R12 정의(탐지 조건, 구현 우선순위 P1~P3, 규칙별 권고 대응 강도 observe/alert/contain) ③ 수집 경로 권고(앱·AI Gateway 이벤트는 GELF 12201로 1회만, Wazuh는 업로드 폴더 FIM만 Syslog 5140으로 전달해 중복 집계 방지) ④ 로그를 목적별로 묶는 Stream 3개(NEXUS_AUTH, NEXUS_AI_SECURITY, NEXUS_WEB) ⑤ Graylog→n8n Webhook 전달 규격과 R1~R12 시험용 입력 ⑥ 앱/Gateway 담당자 구현 요청 항목과 Wazuh/Graylog 구현 순서·완료 기준
- 이시헌: 기획서의 네트워크 부분을 검토하고 pfSense 설정 공유 방법을 질문. 오늘 기한 작업(pfSense 규칙: 공격망에서 포털만 허용)을 수행. 팀 연결표와 로그 전송 프로토콜을 정리해 전달(앱→Graylog UDP 12201, pfSense→Graylog UDP 1514, Wazuh→Graylog UDP 5140). pfSense 경유 포털 접속(5070 포트 포워딩) 동작을 확인하고 기본 진입점을 pfSense 경유 주소로 변경. NAT 때문에 원본 출발지 IP가 보존되지 않아 IP별 공방전 구분은 아직 완료 전임을 확인. 팀원·강사 IP와 내부 API 정상 출처는 실제 서버에서 관찰한 값으로 확정하기로 하고 추정값은 넣지 않음. 보안 로그 계약 어댑터(scripts/log_contract.py: 필수 필드·UTC 시각 검사, 비밀·원문 필드 제외)와 GELF 점검 스크립트(scripts/gelf_probe.py)를 작성하고, 기존 Graylog 탐지 규칙 목록을 우리 사이트에 맞게 변형할 계획을 세움. 팀 알림 채널(#보안알림)에 n8n Discord 알림 시험 메시지를 보냄
- 홍주형: 새 PC에 개발 환경과 DB를 복원하고 오늘 기한 작업(게시판·문서함 코드 방어 점검, 관리자 경로 보호)을 수행. 포털을 외부에서 접속하도록 열고 기밀 문서에 시험용 시나리오 데이터를 넣었으며 팀 관리자 계정을 만듦. 포털 기능을 확장: 자유게시판 그림·PDF 붙여넣기 첨부, 프로필 사진, 인사(인사카드·조직도·근태·휴가), 시스템 관리(사용자 등록·잠금·비밀번호 초기화·감사 로그·권한 현황), 전자결재(양식·참조자·첨부·공문 서식 편집기·지출결의서), 업무·일정·회의실 예약·프로젝트, 자료실·주소록·문서 검색·양식 모음. 최상위 권한 고정, 직급·팀별 권한, 보안 대시보드(위협 지표·추이 그래프·의심 IP·CSV 내보내기)를 구현. 자동 시험이 463개에서 1202개로 늘어 모두 통과했고, 방어 점검 18건·추가 공격 점검 20건이 모두 통과. 시험 중 찾은 결함 9건(동시 신청 중복 저장, 예약 동시 요청, 업로드 권한 오류 등)을 모두 수정. 외부(Kali) 로그인 취약점 점검 결과를 재확인해, 보고된 "느린 무차별 대입 방어 없음"은 실제로는 5회 실패 시 15분 잠금과 IP당 분당 20회 한도로 막히고 있음을 재현으로 확인. 이 작업은 GitHub에 커밋 2건을 푸시했고 일부 기능은 커밋 전

■ 조원별 의견 및 제안 사항

- 김태빈: 직접 인젝션(채팅에 기밀 공개를 직접 요구)과 간접 인젝션(md 같은 문서에 숨긴 지시로 우회)은 구현 방식이 달라지므로 기획서에서 나눌 필요가 있는지 문의. 전체적으로는 잘 짜여 있다는 의견

- 이시헌: pfSense 설정을 export해서 다른 팀원이 그대로 가져다 쓸 수 있는지 문의. 다른 방어전 쪽에서 막히는 사람이 있으면 빠르게 돕겠다고 제안. 다른 과제에 시간이 묶이지 않도록 하겠다는 의견. 완료 기한은 계획서대로 지키고, 부족한 부분은 이후에도 계속 보완하겠다고 확인
- 홍주형: 포털에 이미 보안 이벤트를 남기는 감사 로그 기능이 만들어져 있다고 화면으로 공유하고, 탐지 쪽에서 이 로그를 활용할 수 있다는 점을 확인. 느린 무차별 대입의 추가 강화(잠금 시간 단계적 증가, IP 한도 하향)는 다른 팀이 정상 계정을 일부러 잠가 방해할 수 있어 팀이 함께 정하자고 제안. 포트 443의 Wazuh 화면 외부 노출은 네트워크·탐지 담당이 확인해 달라고 요청. n8n 전용 DB 계정 작업을 위해 n8n이 바꿀 DB 열 목록을 요청
- 진혜정: 감사 로그 화면을 확인하고 좋다는 의견. 이 로그를 탐지 규칙의 입력으로 연결하는 것은 10/20 보안 로그 GELF 전송 작업에서 진행하기로 함. 공방전 날짜가 정해지지 않았고 이후에도 보안 작업이 이어질 수 있으니 빨리 끝내는 편이 낫다고 판단해 10/23 구축 완료로 일정을 잡았음. 시간이 부족하면 편하게 말해 달라고 요청

■ 회의 결과 및 결정 사항

1. 기획서와 팀원별 작업 계획서를 팀 검토를 거쳐 이대로 진행하기로 함
2. 직접/간접 프롬프트 인젝션은 기획서에서 나눈 상태를 유지함. 기획서는 범위를 넓게 잡아도 되고 두 공격 방식이 완전히 같지 않기 때문. 문제가 있으면 한 항목으로 합치기로 함
3. 구축 완료 목표는 10/23(기획서 제출일)이며, 시간이 부족한 사람은 바로 공유하기로 함
4. pfSense 설정 공유는 가능할 것으로 보고 이시헌이 먼저 시도하기로 함
5. AI 에이전트는 홍주형이 마지막에 포털에 연결하기로 하고, AI 관련 작업은 모두 마지막 단계로 모음(기획서·작업 계획서·일정표에 반영)

■ 프로젝트 진행 상황 및 어려운 점

- 진행 상황: 기획서·작업 계획서 완성 및 공유, 팀원별 오늘 기한 작업 수행(AI Agent 관련 항목은 오늘 할당량에서 제외). 포털은 업무·인사·전자결재·보안 대시보드까지 구현되고, n8n은 알림 수신·티켓·Discord 연결·상황판까지 동작해 10/20 로그 전송·탐지 연결 작업으로 이어갈 수 있는 상태
- 어려운 점: ① pfSense 설정을 다른 사람이 그대로 받아 쓸 수 있는지 아직 확인 전 ② 공방전 일정 미정 ③ Ollama를 올릴 장비 미정 ④ pfSense NAT 때문에 공격 팀별 원본 출발지 IP가 보존되지 않아, 출발지 IP별 티켓 구분 방법을 확인해야 함 ⑤ 알림 채널에 연결된 n8n이 팀원별로 따로 있어 최종 n8n 위치 확정 필요 ⑥ 느린 무차별 대입 추가 강화 여부와 방식 결정 필요 ⑦ 공방전 전에 팀 관리자 계정의 초기 비밀번호 변경 여부 확인 필요

■ 향후 활동 계획 및 역할 분담

- 10/20: 홍주형 n8n 전용 DB 계정·대응 열(진혜정이 열 목록 전달), 보안 로그 GELF 전송, 시험 계정·잠금 절차, 미커밋 기능 푸시 / 김태빈 Graylog 입력·필드 추출 / 진혜정 n8n 대응 워크플로(계정 잠금·알림·티켓), 홍주형에게 DB 열 목록 전달 / 이시헌 Kali 공격 재현 스크립트
- 10/21: AI와 무관한 규칙(R1, R5~R10)과 n8n 연결, 해제 절차·티켓 4종, 통합 점검 1차
- 10/22: 통합 점검 2차(동시 공격 시험, 오탐 조정, 증거 캡처), 점검에서 나온 포털 문제 수정
- 10/23: 기획서 제출, 구축 완료 점검
- 마지막 단계(AI Agent 연동, 홍주형 님이 마지막에 연결하는 시점에 맞춰 진행): 홍주형 AI Agent 연결, 이시헌 Ollama 서버, 김태빈 AI 이벤트 로그 수집과 AI 관련 규칙(R2~R4, R11, R12) 탐지 구성, 진혜정 AI 규칙 대응(세션 종료·AI Tool 제한) 연결과 시험

■ 증거 자료

- 회의: 오전 디스코드 텍스트 회의 기록(기획서·작업 계획서 검토, 결정 사항)
- 조원별 작업 보고서: 팀 Notion '회의 및 작업내용'(10/19) 페이지
- 증거 사진(인당 2~4장, 총 12장, 이 문서 끝에 첨부)
  - · 진혜정(3장): 웹훅 수신 워크플로 구성도, 워크플로 실행 기록(성공), 상황판 티켓 화면
  - · 홍주형(4장): 보안 대시보드, 권한 현황, 전자결재 상신(서식 편집기), 일정
  - · 이시헌(3장): pfSense NAT 규칙, Graylog 기존 탐지 규칙 목록, #보안알림 Discord 시험 알림
  - · 김태빈(2장): 보안 로그 명세 초안 v1.1 발췌(탐지 규칙 R1~R12 표, 수집·탐지 흐름도)

증거 사진 (조원별 2~4장)

진혜정

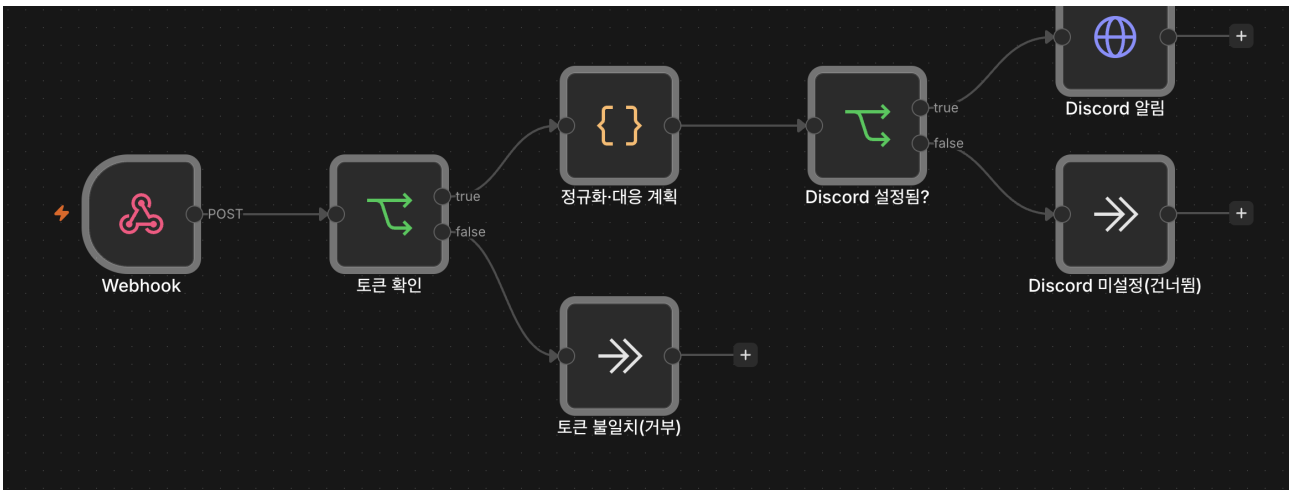


사진 1. 웹훅 수신 워크플로 구성도(Webhook → 토큰 확인 → 정규화·대응 계획 → Discord 설정됨? → 알림/건너뜀)

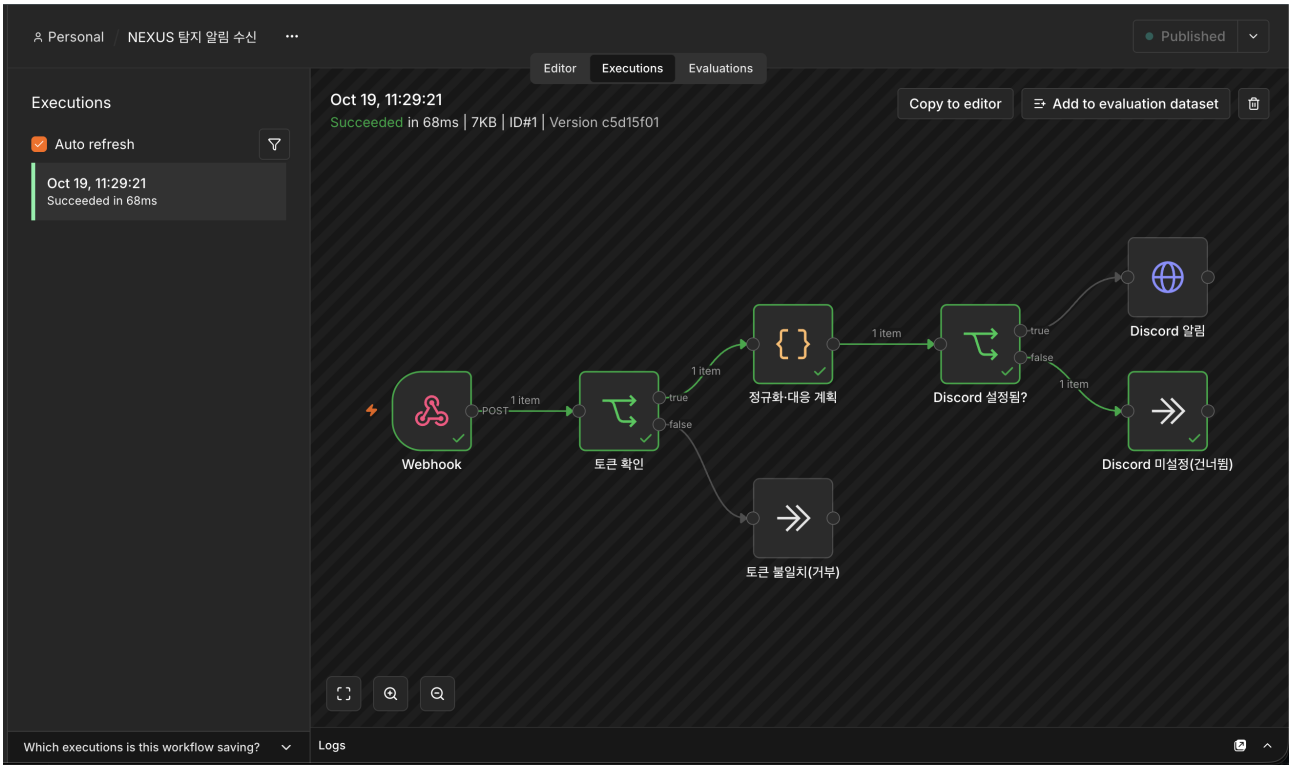


사진 2. 워크플로 실행 기록: 시험 알림 수신 후 모든 노드 성공(Succeeded in 68ms)

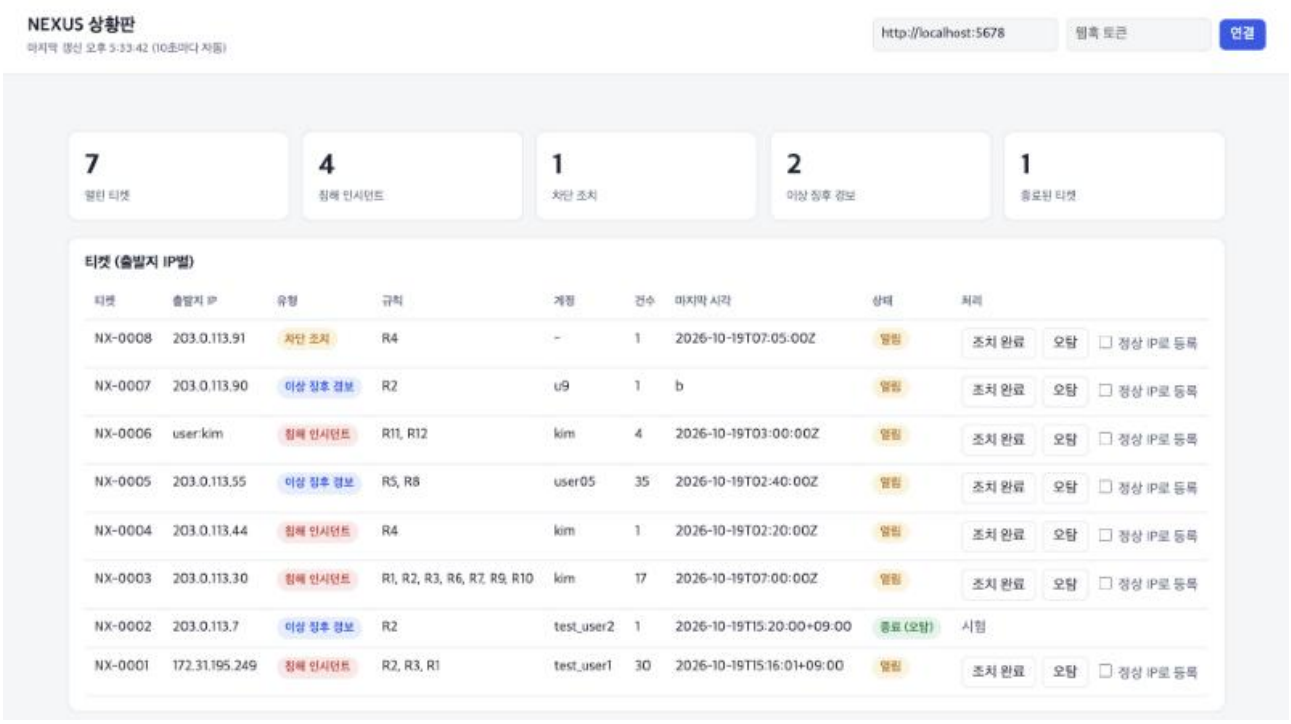


사진 3. 상황판: 출발지 IP별 티켓(열린 7·종료 1), 침해 인시던트 4·차단 조치 1·이상 징후 경보 2 — 시험 알림으로 생성된 실제 n8n 티켓 데이터

홍주형

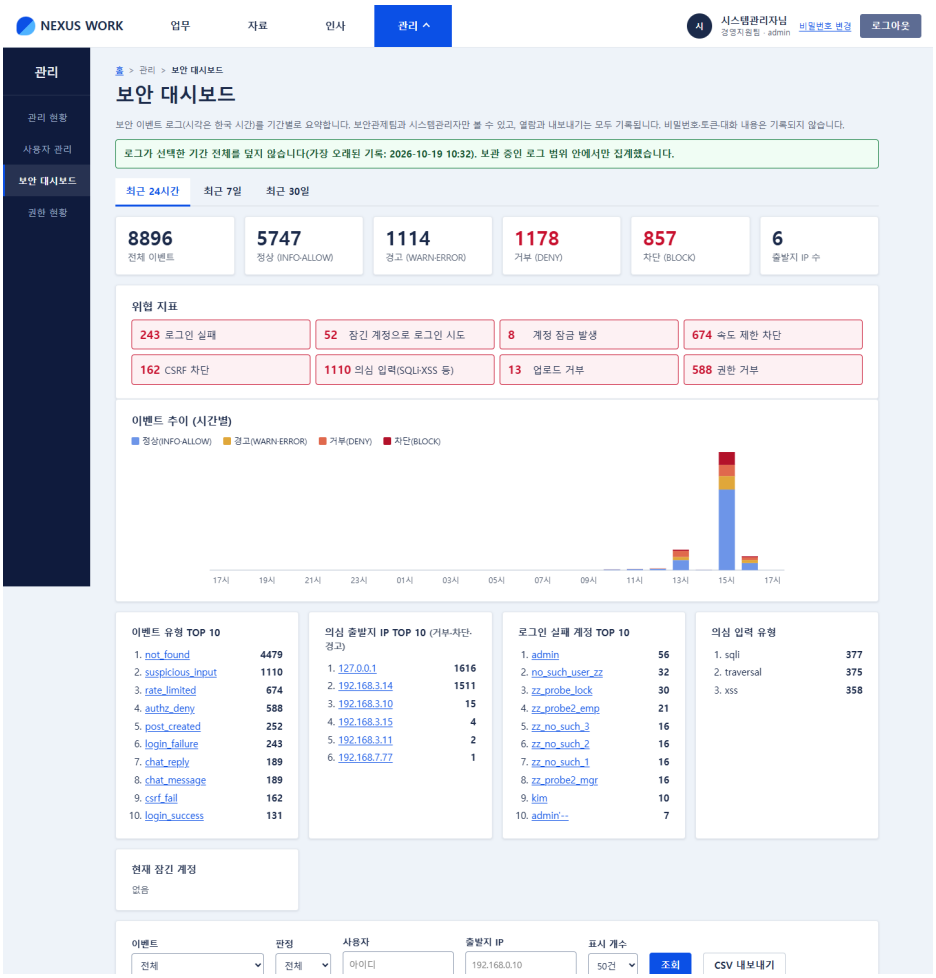


사진 4. 보안 대시보드(최근 24시간): 위협 지표 8종, 시간별 추이, 의심 IP·로그인 실패 계정 상위 목록



사진 5. 권한 현황: 최상위 권한 고정 계정과 직급별 권한표(서버 판정 규칙 기준)

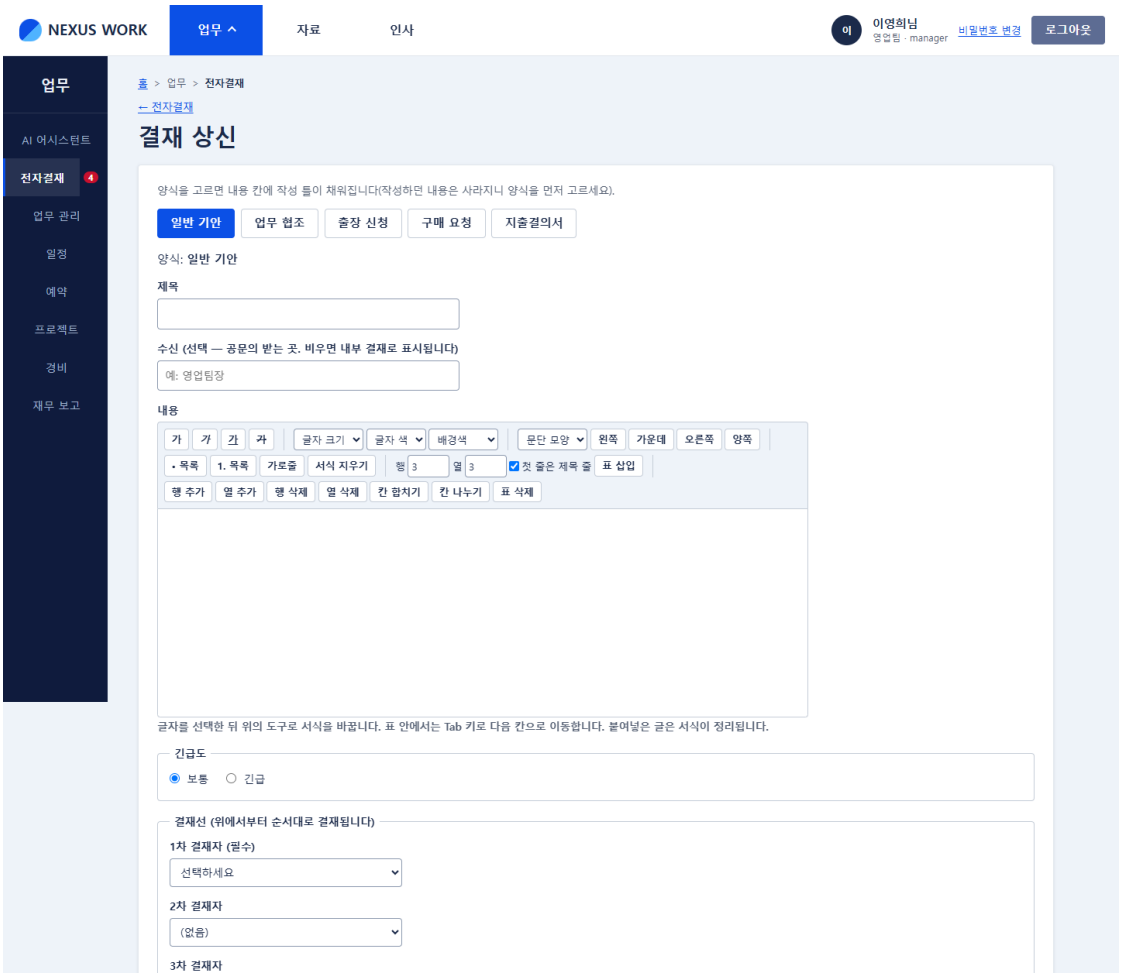


사진 6. 전자결재 결재 상신: 양식 선택, 서식 편집기, 결재선·참조자·첨부

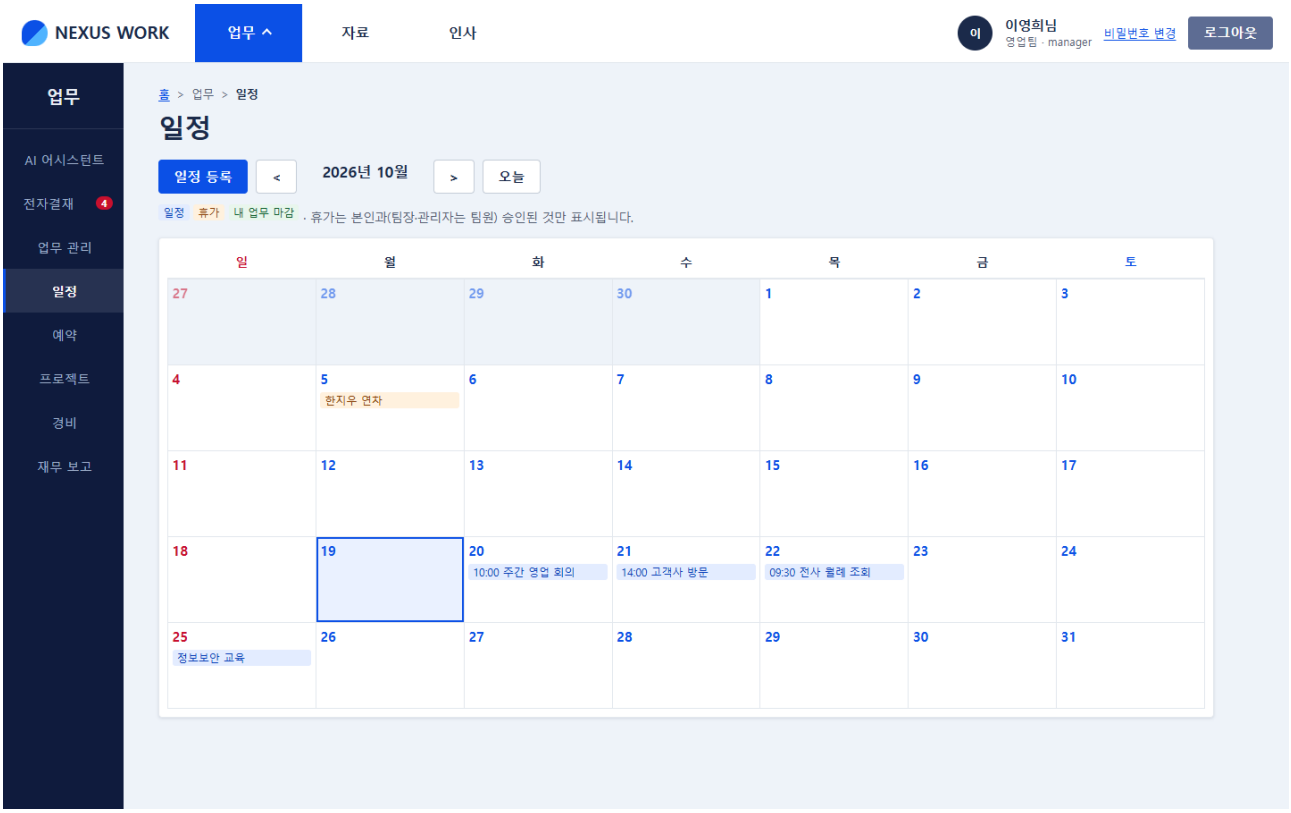


사진 7. 업무 〉 일정(월간 달력): 일정·휴가·업무 마감 표시

이시헌

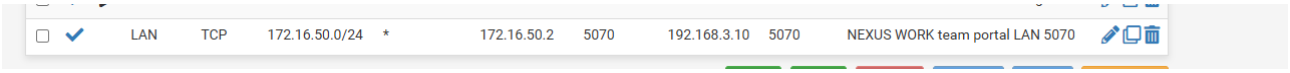


사진 8. pfSense NAT 규칙: LAN(172.16.50.0/24)에서 포털 5070 포트 포워딩



사진 9. Graylog 기존 탐지 규칙 목록(브루트포스·스캔·FIM 등) — 우리 사이트에 맞게 변형 예정

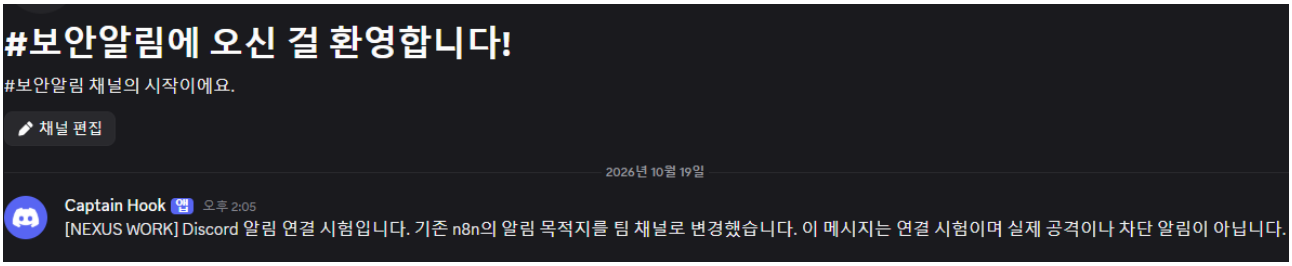


사진 10. #보안알림 채널에 n8n Discord 알림 연결 시험 메시지가 도착한 화면

김태빈

보안 로그 명세 초안 v1.1 — Graylog 탐지 규칙 R1~R12

작성: 김태빈(C 탐지) · 2026-10-19 · SECURITY_LOG_SPEC.md §4 발췌(규칙 ID·탐지 조건·구현 우선순위·권고 대응 강도)

규칙	표시 이름	탐지 조건	우선순위	대응 강도
R1	계정 침해 의심	5분 내 로그인 실패 3회 이상 뒤 성공, 또는 계정 잠금	P1	contain
R2	직접 Prompt Injection 차단	prompt_injection_detected + direct + DENY	P1	alert
R3	AI Tool 권한 위반	보호 Tool 호출의 권한 거부	P1	contain
R4	비정상 Internal API 호출	허용 출처 목록 밖의 내부 API 호출(ALLOW/DENY 구분)	P1	contain
R5	계정 스프레이	같은 IP에서 5분 내 서로 다른 계정 5개 이상 로그인 실패	P2	alert
R6	잠금 후 로그인 재시도	계정 잠금 뒤 5분 내 재시도 3회 이상	P2	alert
R7	심야 로그인 성공	한국시간 00:00~05:00 로그인 성공	P3	observe
R8	404 경로 스캔	같은 IP에서 60초 내 not_found 30회 이상	P3	alert
R9	관리자 권한 접근 거부	일반 사용자의 관리자 경로 접근 거부	P2	alert
R10	기밀 문서 직접 접근 거부	직원의 기밀·재무 경로/자원 접근 거부	P2	alert
R11	AI Tool 반복 권한 위반	5분 내 보호 Tool 거부 3회 이상	P3	contain
R12	콘텐츠 기반 위험 Tool 호출	콘텐츠 입력 → AI 열람 → 보호 Tool 거부의 연결	P3	contain

※ 이 이미지는 김태빈 님이 작성한 명세 문서의 표를 그대로 옮겨 그린 발췌 화면입니다.

사진 11. 보안 로그 명세 초안 v1.1 발췌: Graylog 탐지 규칙 R1~R12(탐지 조건·우선순위·대응 강도)

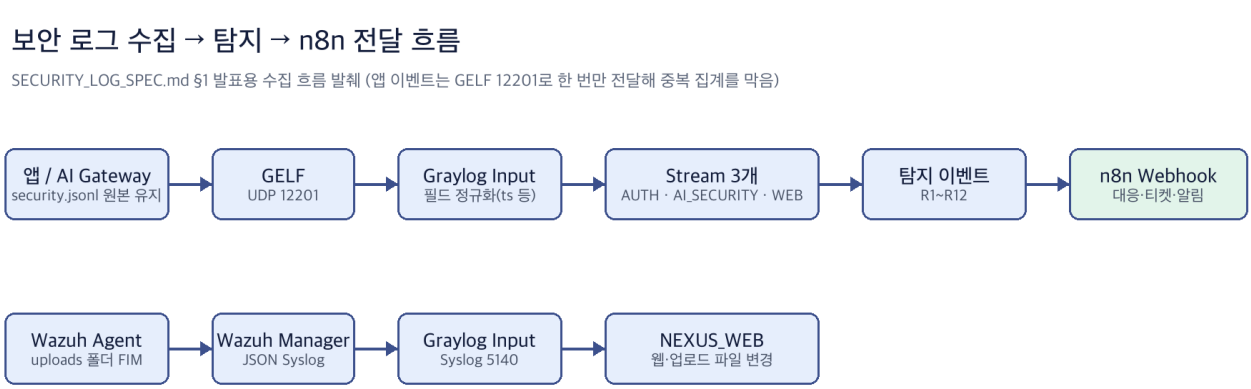


사진 12. 보안 로그 명세 초안 v1.1 발췌: 로그 수집 → Graylog → Stream → n8n 전달 흐름